

한세대학교 전임교원 시간표 조회 사이트 보안점검 결과 보고

점검 대상	https://prof-time-table.vercel.app/index.html	점검 일자	2026.05.12
사이트명	한세대학교 2026-1 전임교원 시간표 조회 (미래전 략 TFT/AX혁신분과)	점검 부서	정보전산원 전산정보팀·정보보호팀
운영 환경	호스팅: Vercel (클라우드) / 백엔드: Supabase (BaaS)	점검 기준	OWASP Top 10, 개인정보보호법, ZT 2.0 등

종합 평가: 매우 취약 (Critical)

클라이언트 측 인증정보·DB 키 평문 노출, 인증 우회 가능, 전임교원 성명 정적 노출, 보안 헤더 미적용 등 서비스 운영에 치명적인 다수 결함이 확인됨에 따라 즉시 비공개 전환을 권고함.

주요 취약점 현황

위험도	취약점 항목	발견 근거 (취약 위치 및 내용)	예상되는 보안 위협 및 영향
Critical	하드코딩 인증정보 (CWE-798)	script.js에 계정(admin/1234, hansei/axgurtls) 평문 노출	누구나 브라우저 소스 열람만으로 로그인 및 접근 통제 무력화
Critical	Supabase DB 키 노출	SUPABASE_URL, SUPABASE_KEY가 JS 코드 내에 평문으로 포함됨	RLS 정책 미비 시, 공격자가 DB를 직접 조작(데이터 변조·삭제) 가능
Critical	클라이언트 인증 우회	서버 검증 없이 localStorage.isLoggedIn='true' 한 줄로 로그인 판정	개발자 콘솔에 한 줄 입력하는 것만으로 손쉽게 로그인 우회 성공
Critical	개인정보 정적 노출	data.js 파일에 교원 성명 다수 포함, 비인가자 URL 직접 접근 가능	본교 전임교원 개인정보 유출 (개인정보보호법 § 29 위반 소지)
High	관리자 페이지 노출	committee.html 직접 진입 가능. 엑셀 업로드/DB 동기화 기능 노출	비인가자에 의한 시간표 데이터 변조 및 시스템 무결성 훼손
High	보안 헤더 미적용	CSP, X-Frame-Options 등 보안 헤더 전면 누락. CORS(*) 허용	XSS, Clickjacking 공격 및 외부 도메인에서의 CORS 남용 위험
High	CDN SRI 미적용	외부 라이브러리(sheetjs, supabase) 호출 시 무결성 해시 없음	CDN 서버 변조 시 악성 스크립트가 실행되는 공급망 공격 노출
Medium	잠재적 XSS 요소	data.js 동적 로딩을 위해 document.write 함수 사용	최신 브라우저 차단 가능성 및 DOM 기반 XSS 공격의 잠재적 벡터
Medium	브라우저 정보 잔존	로그아웃 후에도 localStorage에 committees 민감 데이터 잔존	공용 PC 사용 시 후속 사용자에 의한 내부 정보 노출 위험

권고 조치 (우선순위)

[P0] 24시간 내 즉시 조치

- 사이트 비공개 전환 또는 교내망 IP 화이트리스트 적용
- data.js 내 전임교원 명단 정적 노출 제거 (API 호출로 전환)

[P1] 2주 내 조치

- Supabase RLS 정책 점검 및 anon key 접근 권한 최소화
- vercel.json 설정 통해 필수 보안 헤더 7종 적용
- committee.html 관리자 페이지 서버사이드 인증·인가 분리

[P0] 1주일 내 조치

- 하드코딩된 ID·PW 완전 제거
- 본교 도입 완료 Bandi SSO(CC인증·국정원 검증) 연동 적용

[P2] 1개월 내 중장기 조치

- 외부 CDN 스크립트 SRI(Subresource Integrity) 해시 적용
- document.write 로직 제거
- 정보시스템 도입 절차(26.02.01)에 따른 전산정보팀 협의 사후 보고

■ 컴플라이언스 위반 소지

- 개인정보보호법 제29조(안전조치의무): 비인가 접근이 가능한 스크립트에 전임교원 성명 평문 노출
- 교육부 정보보안 기본지침: 정보시스템 도입 시 인증 및 접근통제 조치 미흡
- 본교 다중 AI/시스템 도입 운영지침 § 4.2: 교직원 개인정보 외부망(Vercel) 무단 노출 우려
- 본교 정보시스템 도입 절차 (2026.02.01 시행): 신규 외부 시스템 활용 시 전산정보팀 사전 기술검토 누락

진행 및 후속 조치 사항

- 개발팀(미래전략 TFT/AX혁신분과) 공식 점검결과 통보 및 조치계획 수령
- 정보보호팀 사고대응 로그 기록 (개인정보 외부 노출 가능성)
- 정보화추진위원회 안전화: 외부 클라우드 서비스 활용 가이드라인 수립
- 해당 서비스의 교내 Bandi SSO 연동 가능 여부 기술 검토

추가 미확인 사항 (확인 요망)

- Supabase RLS(행 단위 보안) 정책 실제 설정 여부 (개발팀 협조)
- Vercel 프로젝트 소유자 계정의 본교 정보 자산 정식 등재 여부
- 전임교원 성명 외부에 게시함에 따른 개인정보 수집·이용 동의서 확보 여부
- 본 시스템의 정보화추진위원회 개발/운영 공식 보고 및 승인 여부

출처 분류: [참고자료] 외부 사이트 직접 점검 / [완료] Bandi SSO·HCI 등 본교 기 도입 자산 / [협조] 26.02.01 시행 정작성: 정보전산원 전산정보팀·정보보시스템 도입 절차 보호팀